BoletaYa

Propuesta de arquitectura, operación, seguridad y costos

Amazon DynamoDB · Escenarios A y B · 4 de noviembre de 2026

Recomendación ejecutiva

Adoptar el Escenario A: aplicación y base de datos en AWS; operación del estadio local en ambos escenarios. Ofrece menor latencia estimada y reduce dependencias de conectividad en el camino de compra. El presupuesto total queda pendiente de cotizaciones de proveedores y validación de calculadora.

El documento distingue datos calculados, estimaciones y vacíos. No presenta estimaciones como ofertas comerciales ni como pruebas de infraestructura productiva.

Propuesta escrita — BoletaYa

Estado: propuesta integrada para exportar a PDF (máximo 25 páginas sin anexos), actualizada el 2026-11-04. Cifras no cotizadas se identifican como estimaciones o pendientes; no son compromisos comerciales.

Leyenda: OK hay material suficiente · PARCIAL hay material con huecos · PENDIENTE falta el material

Presupuesto de páginas (25 sin anexos)

Sección	Páginas	Estado
0. Resumen ejecutivo y recomendación	1	OK recomendación A, costo total condicionado
1. Contexto, supuestos y contradicciones del enunciado	1	OK
2. Escenarios A y B (incluye análisis DynamoDB on premise)	3	OK
3. Capacidad (5.1)	3	OK
4. Concurrencia y consistencia (5.2)	3	OK
5. Versiones y licenciamiento (5.3)	1,5	OK
6. Arquitectura (5.4)	3	OK diseño documentado; medidas de latencia estimadas
7. Recuperación (5.5)	3	PARCIAL
8. Seguridad y cumplimiento (5.6)	2	OK con validación jurídica/contrato pendiente
9. Costos (5.7)	2	PARCIAL subtotal recalculado; faltan cotizaciones
10. Decisión final (5.8)	1	OK recomendación A
11. Respuesta a la carta de evento	1,5	PENDIENTE aún no llega
Total	25	

Anexos (no cuentan en las 25): A. Registro de decisiones (`integracion/registro_decisiones.md`) · B. Análisis de concurrencia (`david/anexo_concurrencia.md`) · C. Estudio de conmutación (`david/alta_disponibilidad.md`) · D. Modelo de datos completo (`jacobo/modelo_datos.md`) · E. Volumetría y fórmulas (`jacobo/capacidad_y_volumetria.md`) · F. Runbooks (`miguel/recuperacion_licenciamiento_carta.md` §5.5) · G. Referencias (`jacobo/referencias.md` y las de cada carpeta).

---

0. Resumen ejecutivo (1 página) PARCIAL

• Motor y nube asignados: Amazon DynamoDB en AWS.

• Escenario A: todo en AWS (aplicación y base); el estadio es local. Escenario B: híbrido aceptado por el profesor: aplicación, caché y estadio en Bogotá; base en AWS por Direct Connect.

• El pico manda: 24.000 órdenes en 20 minutos, unas 20 por segundo. DynamoDB on-demand con pre-calentamiento lo absorbe por unos USD 83 de throughput al año (año 1, us-east-1).

• Cero doble venta: escritura condicional dentro de una transacción todo o nada; 50 de 50 casos pasan en un simulador.

• Pérdida de región: una sola región escribe; se congelan las sillas en duda y se reabre en 4 a 11 minutos estimados (sin medir); el RPO 0 de pagos sale de la conciliación con Mercado Pago.

• Costos: los costos de nube se estiman; CAPEX del estadio, cola virtual y conectividad requieren cotización. Los subtotales del Excel no son costo total aprobado.

• Recomendación provisional: Escenario A, por menor latencia, menor dependencia de conectividad Bogotá-AWS y menor complejidad operativa. Su viabilidad presupuestal permanece sin certificar hasta cerrar las líneas pendientes.

1. Contexto, supuestos y contradicciones (1 página) OK

• Supuestos numerados A-01 a A-12: `jacobo/README.md` §4.

• Contradicciones del enunciado y cómo se resolvieron (60.000 boletas frente a 45.000 sillas; 4,42 M frente a 4,0 M boletas; "100 ventas por minuto" frente a 8,3; CPU e IOPS que DynamoDB no expone): `jacobo/README.md` §5 y `jacobo/entrega_para_el_equipo.md` §6.

• Respuestas del profesor del 2026-11-04 que fijan la interpretación: `david/respuestas_profesor.md`.

2. Escenarios A y B (3 páginas) PARCIAL

• Definición de cada escenario según el profesor (resp. 1 y 2): `david/respuestas_profesor.md`.

• **Por qué DynamoDB no va on premise y evaluación de una alternativa compatible con su API (máximo 2 páginas, pedido explícito del profesor): PENDIENTE la escribe Jacobo**. Insumos ya existentes: `jacobo/resumen_sustentacion.md` P10 y `jacobo/arquitectura.md` §3.

• Comparación A contra B en latencia por compra, conectividad con Bogotá, egress y costos (resp. 2): PARCIAL la latencia ya está (≈ 353 ms por compra en B frente a ≈ 22 ms en A, `jacobo/resumen_sustentacion.md` P18); faltan egress y costos (Juan Pablo).

3. Capacidad — 5.1 (3 páginas) OK

Fuente: `jacobo/capacidad_y_volumetria.md`, `jacobo/calculos/salida_modelo.md`.

Dato	Valor
Operación normal	0,056 órdenes/s ≈ 3,5 WRU/s
Preventa	24.000 órdenes en 20 min = 20/s; 55,3 WRU por orden (mínimo), 84,4 (planificación), 182,9 (estrés)
Pico de escritura	≈ 1.690 WRU/s promedio; ≈ 8.440 WRU/s en ráfaga ×5; 10.546 con margen del 25 %
Mapa de sillas	250.000 personas = 25.000 consultas/s = 17,2 × la cuota de una tabla; con instantáneas en CDN la base ve ≈ 450 RRU/s
Almacenamiento en línea	48,0 GiB (año 1) a 231,8 GiB (año 5)
Opciones de pico, throughput año 1 (USD)	On-demand 83–124 · provisionado programado 880–1.319 · provisionado fijo 63.176–94.764

Qué va a la base y qué no: a la base, bloquear, confirmar, boletas, escaneos y contador; fuera de ella, el mapa (CDN), la posición en la cola, el catálogo (caché) y el histórico (S3 + Athena). `jacobo/resumen_sustentacion.md` P4.

4. Concurrencia y consistencia — 5.2 (3 páginas) OK

Fuente: `david/concurrencia.md`, `david/anexo_concurrencia.md`, `david/estadio.md`.

• Qué es doble venta según el profesor (resp. 5): `david/concurrencia.md` §0.

• Cómo se evita: escritura condicional sobre el ítem de la silla dentro de `TransactWriteItems`; transacciones serializables entre sí; el bloqueo de 8 minutos vive en la silla y el TTL solo limpia. Ficha F-06.

• Pago confirmado sin registro y al revés: idempotencia (`X-Idempotency-Key = <oid>#<nn>`), estado del intento de pago, reconciliador cada minuto, SQS con cola de fallidos. `david/concurrencia.md` §6.

• Deadlocks: no hay bloqueos que esperen; un choque cancela la transacción y se reintenta con backoff y jitter (máximo 3). `david/concurrencia.md` §7.

• Antibots: máximo 10 sillas por usuario y evento, en la misma transacción. `david/concurrencia.md` §8.

• Estadio sin internet: un nodo por puerta como autoridad, 4 horas aislado. Ficha F-13.

• Evidencia: 50 de 50 casos pasan en un simulador (moto). Aclarar en el texto que es un simulador local, no AWS real.

5. Versiones y licenciamiento — 5.3 (1,5 páginas) OK

Fuente: `miguel/recuperacion_licenciamiento_carta.md` §5.3; `david/estadio.md` §9.1.

• DynamoDB no tiene versión, edición ni licencia por núcleo: escalar o replicar no agrega licencias.

• Lo que sí tiene fin de soporte: SDK de AWS, runtime (Node.js 24 hasta abril de 2028 o Python 3.14 hasta junio de 2029), ElastiCache para Valkey, y en el estadio Ubuntu 26.04 LTS (mayo de 2031) y PostgreSQL 18 (noviembre de 2030).

• Plan de actualización costeado: COP 15.360.000 en 5 años más Ubuntu Pro.

• Hueco: el lenguaje de la aplicación no está decidido (por eso hay dos runtimes).

6. Arquitectura — 5.4 (3 páginas) PARCIAL

Fuente: `jacobo/arquitectura.md` (diagramas Mermaid de A y B), `david/alta_disponibilidad.md` §2.

• Región us-east-1 (≈ 77 ms desde Bogotá) con alterna us-east-2. Ficha F-02.

• Alta disponibilidad: 3 zonas dentro de la región (RPO 0, SLA 99,99 %); MREC hacia us-east-2 con una sola región que escribe.

• La venta se conmuta por DNS o a mano: CloudFront no conmuta `POST`.

• Escenario A es nube completa para la ruta de compra; el estadio sigue local en A y B. Verificación: AWS no lista región colombiana; la Local Zone de Bogotá está anunciada/no disponible y no ofrece DynamoDB confirmado. Latencia medida como proxy de tercero (77 ms Washington/us-east-1, 112 ms São Paulo) y estimaciones por compra: A ~22 ms, B ~350 ms; no son medidas de endpoint/transacción.

7. Recuperación — 5.5 (3 páginas) PARCIAL

Fuente: `miguel/recuperacion_licenciamiento_carta.md` §5.5; `david/alta_disponibilidad.md` §3.

Componente	Meta RPO / RTO	Alcanzado (estimado)
Venta, falla de zona	0 / 15 min	0 / sin conmutación
Venta, pérdida de región	0 / 15 min	Pagos 0 con sillas en duda congeladas; RTO 4 a 8 min (4 a 11 en secuencia) desde la declaración; detección 2 a 5 min aparte
Venta, pérdida del data center (solo B)	0 / 15 min	0 / 3 a 11 min
Ingreso al evento	Nunca se detiene	RPO 0 y RTO 0 sin internet; 5 a 10 min si cae el nodo de una puerta
Usuarios y catálogo	15 min / 4 h	Segundos con PITR / minutos a horas
Histórico	24 h / 48 h	Hasta 24 h / horas

• Respaldo: PITR 35 días, AWS Backup diario y mensual con copia a otra región y otra cuenta, Vault Lock. Ficha F-12.

• Respaldo sin afectar la preventa: según AWS, PITR, respaldos y exportaciones no consumen capacidad; aun así, congelamiento de cambios de 24 h antes a 3 h después de cada preventa y respaldos de madrugada.

• Runbooks 1, 2a, 2b, 2c y 3, y plan de pruebas (68 horas de DBA al año).

• Runbook 2b actualizado: paso 4 obtiene las sillas en duda de `bya_ledger`; los tiempos del RTO siguen estimados, no medidos en infraestructura AWS.

8. Seguridad y cumplimiento — 5.6 (2 páginas)

8.1 Controles técnicos y roles

Se aplica mínimo privilegio con identidades separadas: (1) servicio de compra: solo lectura/escritura sobre las tablas y acciones necesarias; (2) procesos de Streams/Lambda: permisos sobre su tabla, cola y destino; (3) DBA: acceso temporal y auditado de operación, sin acceso ordinario a datos de tarjeta; (4) organizador: catálogo, precios y cupos de su evento, sin administrar IAM ni consultar datos de otros eventos; (5) soporte: consulta enmascarada y acceso elevado con aprobación temporal; (6) auditor: lectura de bitácoras y exportaciones inmutables. MFA para personas, roles temporales, secretos fuera del código, revisión periódica de permisos y separación de cuentas de producción/respaldo.

DynamoDB, S3 y respaldos se cifran en reposo con AWS KMS (CMK administrada por el cliente para información sensible), rotación y separación de permisos de uso/administración. TLS vigente para APIs, SDK, pagos, Direct Connect/VPN y replicación compatible. S3 usa bloqueo de acceso público, versionado, políticas de retención/Object Lock donde aplique y copia a cuenta/región separada. La recuperación prueba que las llaves y políticas también pueden restaurarse; una copia cifrada sin acceso a la llave no es recuperable. CloudTrail registra cambios de control y acceso administrativo; CloudWatch centraliza alarmas; `bya_audit` registra actor, evento, silla, precio anterior/nuevo, motivo y correlación. No registrar PAN, CVV, credenciales ni tokens secretos; enmascarar identificadores personales en logs y restringirlos por retención/rol.

8.2 PCI DSS y pasarela

La aplicación redirige o delega la captura a Mercado Pago y conserva solo identificadores/token de referencia, estado, monto y metadatos mínimos. No recibe, procesa ni almacena PAN/CVV; logs, trazas, backups, eventos y exportaciones excluyen datos de tarjeta. Esto reduce el alcance PCI DSS, pero no permite declarar automáticamente “fuera de PCI”: la clasificación depende del flujo real del Checkout y de la validación del adquirente/asesor PCI. Antes de producción se revisa el SAQ aplicable, se documenta la integración y se prueba que los datos de tarjeta no aparecen en ningún canal. Una filtración de PAN/CVV invalida el supuesto y activa respuesta a incidentes.

8.3 Antifraude y antibots

WAF/Shield y la cola virtual filtran abuso volumétrico; CAPTCHA/rate limits y tokens de admisión reducen automatización. La regla crítica también vive en la base: máximo 10 sillas por usuario/evento se aplica dentro de la transacción; escritura condicional impide reservar una silla no disponible. Los límites de borde no son control de integridad. Auditar cambios de precio, inventario, descuentos, cupos y asignación manual con doble aprobación, motivo obligatorio y alerta; toda venta valida precio y silla contra la fuente de verdad transaccional.

8.4 Datos personales y transferencia/transmisión internacional

La operación envía datos de titulares colombianos a infraestructura AWS en EE. UU. Si BoletaYa decide fines/medios y AWS procesa por cuenta de BoletaYa, el flujo se analiza como transmisión internacional (responsable en Colombia a encargado en el exterior); si se comunica a un receptor que actúa como responsable independiente, es transferencia. El artículo 26 de la Ley 1581/2012 prohíbe transferir a países sin nivel adecuado, salvo excepciones o declaración SIC. El numeral 3.2 del Título V de la Circular Única vigente incluye a Estados Unidos entre países adecuados. Esto permite la transferencia al país listado, sujeto a confirmar la calificación del flujo y a responsabilidad demostrada: contrato de transmisión/instrucciones, finalidades, minimización, medidas de seguridad, atención de titulares, gestión de subencargados/incidentes y evidencia de cumplimiento. La inclusión del país no exime de la Ley 1581 ni resuelve por sí sola la transmisión contractual.

Retención tributaria: el Estatuto Tributario, art. 632, obliga a conservar informaciones y pruebas relevantes para obligaciones tributarias durante el término allí previsto; la Ley 962/2005, art. 46, establece que el período del art. 632 corre hasta que quede en firme la declaración de renta soportada por esos documentos. En consecuencia, no fijar una eliminación universal a dos años: comprobantes contables, facturas y soportes tributarios se retienen, como mínimo, hasta firmeza de la declaración aplicable (el texto base del art. 632 habla de cinco años, pero el art. 46 de la Ley 962, modificado por el art. 304 de la Ley 1819/2016, dispone conservar por el mismo término de firmeza de la declaración tributaria correspondiente; hay categorías y excepciones que deben revisarse por obligación). Definir calendario por clase documental con asesor tributario, suspensión por litigio/auditoría y disposición segura al vencer. Datos de cuenta y perfil no necesarios para soporte tributario se minimizan/suprimen conforme a política; seudonimizar órdenes y preservar solo los atributos exigidos. TTL es limpieza operativa, no reemplaza conservación legal en archivo S3 con controles de acceso y Object Lock cuando corresponda.

Fuentes oficiales: Ley 1581/2012, art. 26; Circular Única SIC, Título V, numeral 3.2; Ley 962/2005, art. 46; Estatuto Tributario, art. 632; Ley 1819/2016, art. 304.

9. Costos — 5.7 (2 páginas) PARCIAL

Fuente: `juanpablo/costos_boletaya.xlsx`, `juanpablo/costos_y_dimensionamiento.md`, `juanpablo/sensibilidad_y_tco.md`.

Subtotales parciales de la hoja recalculada (2026-11-04), con rubros valorados y estimaciones, antes de cotizaciones obligatorias pendientes:

	Año 1	Año 5	Estado
Escenario A	COP 113.583.280	COP 23.184.650	INCOMPLETO; año 1 deja margen parcial de COP 166.416.720
Escenario B (opción 2)	COP 129.363.740	COP 38.965.110	INCOMPLETO; año 1 deja margen parcial de COP 150.636.260

Estado y tratamiento: la hoja separa cifras calculadas, estimaciones explícitas y celdas pendientes; sus totales parciales no certifican cumplimiento. La aplicación en A requiere API, cómputo Lambda/contenedores y caché; ElastiCache se estima con el precio/modelo de Jacobo y se etiqueta como estimación. En B la aplicación primaria es local; se costea en CAPEX/OPEX del sitio y se conserva espera en AWS. No duplicar la aplicación cloud completa en ambos escenarios.

Por qué no se puede cerrar todavía (detalle en `integracion/pendientes_entrega.md`):

• Faltan cotizaciones de la cola virtual, Direct Connect y partner, VPN, AWS Backup, el resto del equipo del estadio y la Pricing Calculator.

• Equipo fijo del estadio (servidores, mini PC, switches y torniquetes de opción 1) está en ambos escenarios porque el estadio es local en ambos. F-14 opción 2 excluye torniquetes propios y supone uso de equipo compatible del estadio; lectores/controlador y resto del hardware siguen por cotizar.

• Ya se añadieron líneas de API Gateway y ElastiCache; Lambda queda como estimación explícita (5 invocaciones por orden, 512 MB, 200 ms, sin capa gratuita). No son cotizaciones.

• Los subtotales no incorporan cola virtual, cotización de Direct Connect/cross-connect, VPN/enlace redundante, Backup, egress medido, tarifa final de comisión de pagos, soporte/software local ni componentes de hardware aún sin precio. Por eso no equivalen a costo total ni demuestran cumplimiento del tope.

10. Decisión final — 5.8 (1 página)

Recomendación: desplegar A (aplicación y DynamoDB en AWS; estadio local) como arquitectura objetivo. Los subtotales parciales favorecen A, pero no son presupuesto total hasta cerrar precios pendientes. Comparación:

• Recuperación: A es más simple (sin runbook 2c y sin depender del enlace Bogotá–AWS). `miguel/recuperacion_licenciamiento_carta.md`, final de la sección del Escenario B.

• Latencia: A ≈ 22 ms por compra frente a ≈ 353 ms en B.

• Costo: el Excel quedó incompleto y por tanto no acredita que ninguno cumpla topes. B con torniquetes propios excedía COP 280 M; para B se adopta F-14 opción 2 (usar torniquetes compatibles del estadio y comprar/validar lectores), que elimina el CAPEX de torniquetes propios, pero quedan los demás equipos/cotizaciones. No afirmar “B cuesta 120 M” como total cerrado.

• Riesgo y operación: A elimina el enlace privado en el camino de compra y el runbook de pérdida del data center de Bogotá; B añade Direct Connect/VPN y la operación local de aplicación/caché. Ambos mantienen RPO/RTO de la base y el riesgo de región; el ingreso al estadio sigue local.

• Pico y crecimiento: ambos usan la misma base DynamoDB on-demand, cola de admisión y mapa CDN; el dato fuente evita ventas dobles. B no aporta capacidad de base local.

• Costo de A también tiene vacíos: hardware del estadio es común a A y B, además de cola virtual, cómputo, backups y servicios de borde. No certificar presupuesto hasta llenar precios y recalcular.

11. Respuesta a la carta de evento (1,5 páginas) — pendiente de insumo externo

La carta concreta del evento no está en el repositorio. No se inventan sus condiciones. El plan de continuidad de 72 horas está en `miguel/recuperacion_licenciamiento_carta.md`, sección “Carta de evento”; al recibir la carta se completa con los datos del evento y el plazo formal.